

I. Kiến trúc hệ thống

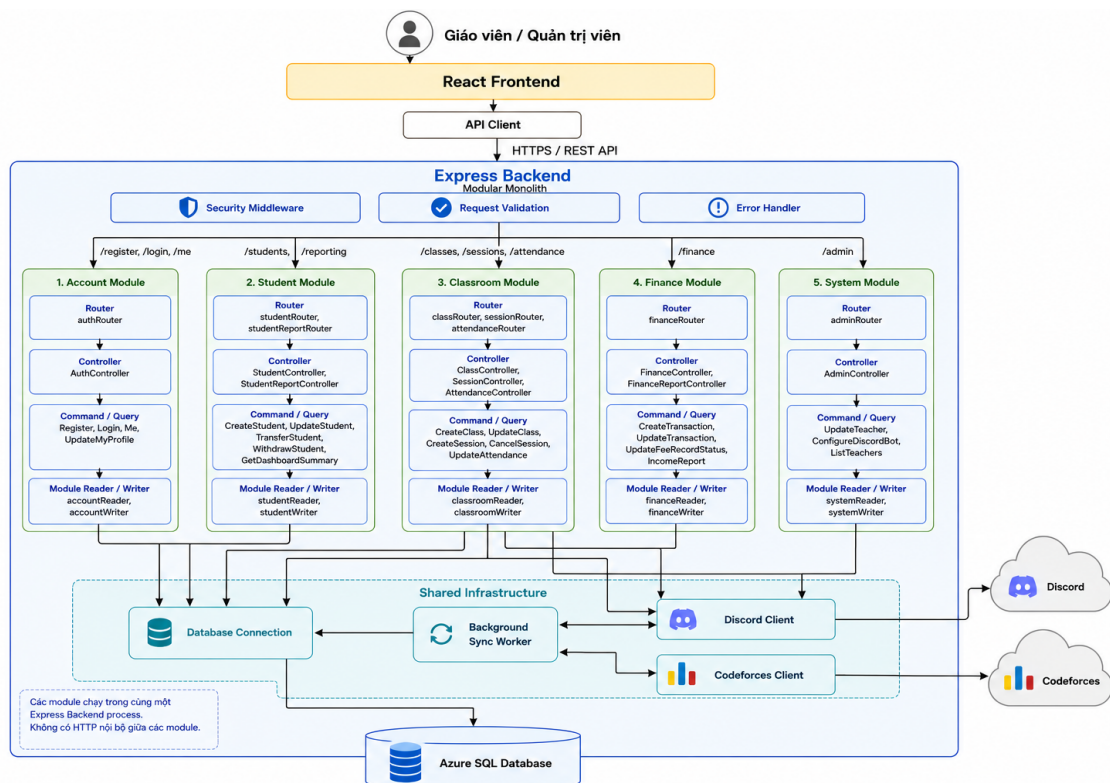
Phần này trình bày kiến trúc tổng thể của hệ thống Tutor Management System (TMS) ở mức thiết kế hệ thống. Nội dung tập trung vào các thành phần chính, cách bố trí các thành phần và quan hệ phụ thuộc giữa chúng. Các luồng nghiệp vụ chi tiết không được lặp lại trong phần này vì đã được mô hình hóa ở phần yêu cầu chức năng.

1. Mô hình kiến trúc

TMS sử dụng mô hình client-server: trình duyệt gửi request đến backend, backend xử lý nghiệp vụ và lưu dữ liệu trên Azure Database Server.

Ở mức triển khai backend, hệ thống chọn kiến trúc modular monolith. Backend vẫn là một ứng dụng duy nhất, nhưng được chia theo các ranh giới nghiệp vụ bên trong. Cách này đủ rõ ràng cho phạm vi đề án và tránh độ phức tạp của nhiều dịch vụ độc lập.

2. Sơ đồ kiến trúc



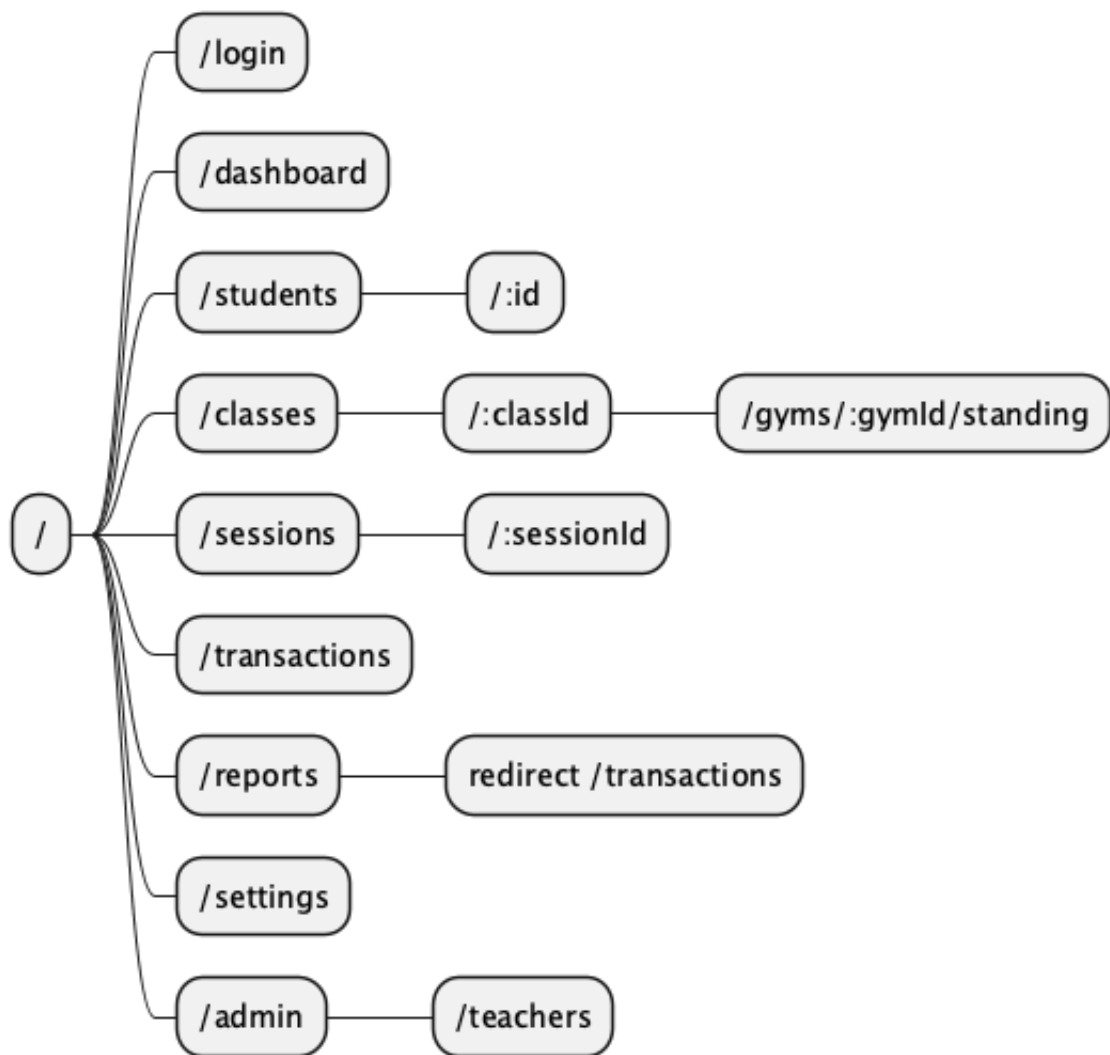
Hình 1: Sơ đồ kiến trúc hệ thống TMS

3. Mô tả các thành phần trong hệ thống

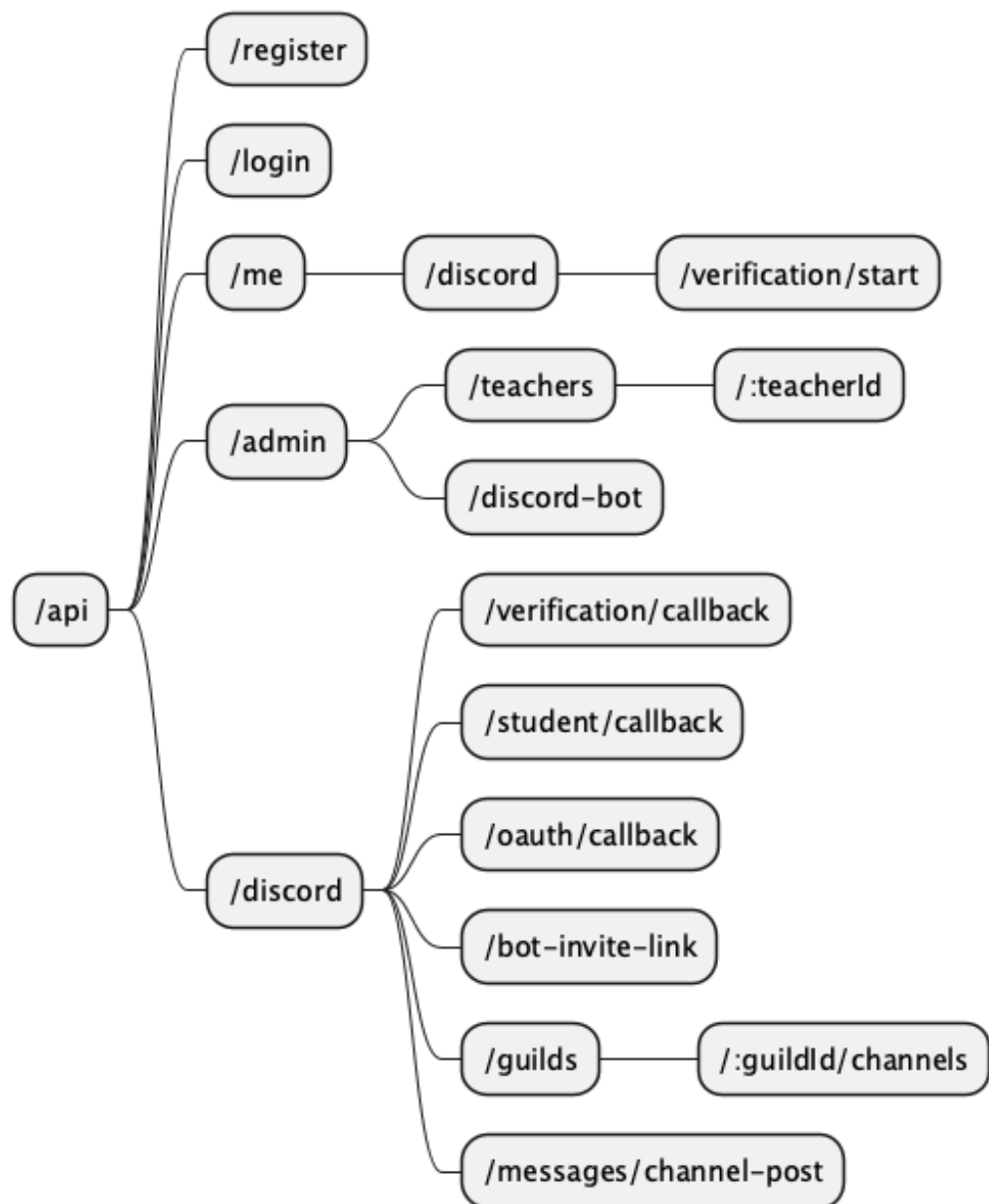
STT	Thành phần	Mô tả
1	Giáo viên / Quản trị viên	Người sử dụng hệ thống thông qua giao diện web. Giáo viên thao tác với dữ liệu lớp học, học sinh, điểm danh và tài chính; quản trị viên quản lý tài khoản và cấu hình hệ thống.
2	React Frontend	Giao diện người dùng chạy trên trình duyệt, cung cấp các màn hình thao tác cho giáo viên và quản trị viên.
3	API Client	Lớp phía frontend chịu trách nhiệm gửi request đến backend thông qua REST API.
4	Express Backend	Ứng dụng backend chính của hệ thống. Backend chạy theo mô hình modular monolith, tiếp nhận request từ frontend và điều phối xử lý nghiệp vụ.
5	Security Middleware	Lớp kiểm soát truy cập trước khi request đi vào module nghiệp vụ, gồm xác thực và kiểm tra quyền truy cập.
6	Request Validation	Lớp kiểm tra dữ liệu đầu vào của request trước khi chuyển vào controller.
7	Error Handler	Lớp chuẩn hóa lỗi và response lỗi trả về cho frontend.
8	Account Module	Module phụ trách đăng nhập, đăng ký, hồ sơ tài khoản và thông tin định danh liên quan đến tài khoản.
9	Student Module	Module phụ trách học sinh, ghi danh, chuyển lớp, rút khỏi lớp và các truy vấn tổng quan liên quan đến học sinh.
10	Classroom Module	Module phụ trách lớp học, lịch học, buổi học, điểm danh và các chức năng học tập liên quan đến lớp.
11	Finance Module	Module phụ trách giao dịch, khoản phí, trạng thái phí và báo cáo tài chính.
12	System Module	Module phụ trách chức năng quản trị hệ thống, gồm quản lý tài khoản giáo viên và cấu hình dùng chung.
13	Database Connection	Thành phần hạ tầng dùng chung để các reader/writer của module truy cập cơ sở dữ liệu.
14	Background Sync Worker	Tác vụ nền dùng để đồng bộ dữ liệu định kỳ giữa hệ thống với các dịch vụ bên ngoài và cơ sở dữ liệu.
15	Discord Client	Thành phần hạ tầng dùng để backend giao tiếp với Discord.
16	Codeforces Client	Thành phần hạ tầng dùng để backend giao tiếp với Codeforces.
17	Azure SQL Database	Cơ sở dữ liệu chính của hệ thống, lưu dữ liệu nghiệp vụ và dữ liệu đồng bộ cần hiển thị trong TMS.
18	Discord	Dịch vụ bên ngoài được tích hợp để hỗ trợ các chức năng liên quan đến lớp học và cộng đồng học viên.
19	Codeforces	Dịch vụ bên ngoài được tích hợp để đồng bộ dữ liệu luyện tập, bài tập và kết quả học tập.

4. Thiết kế API endpoint

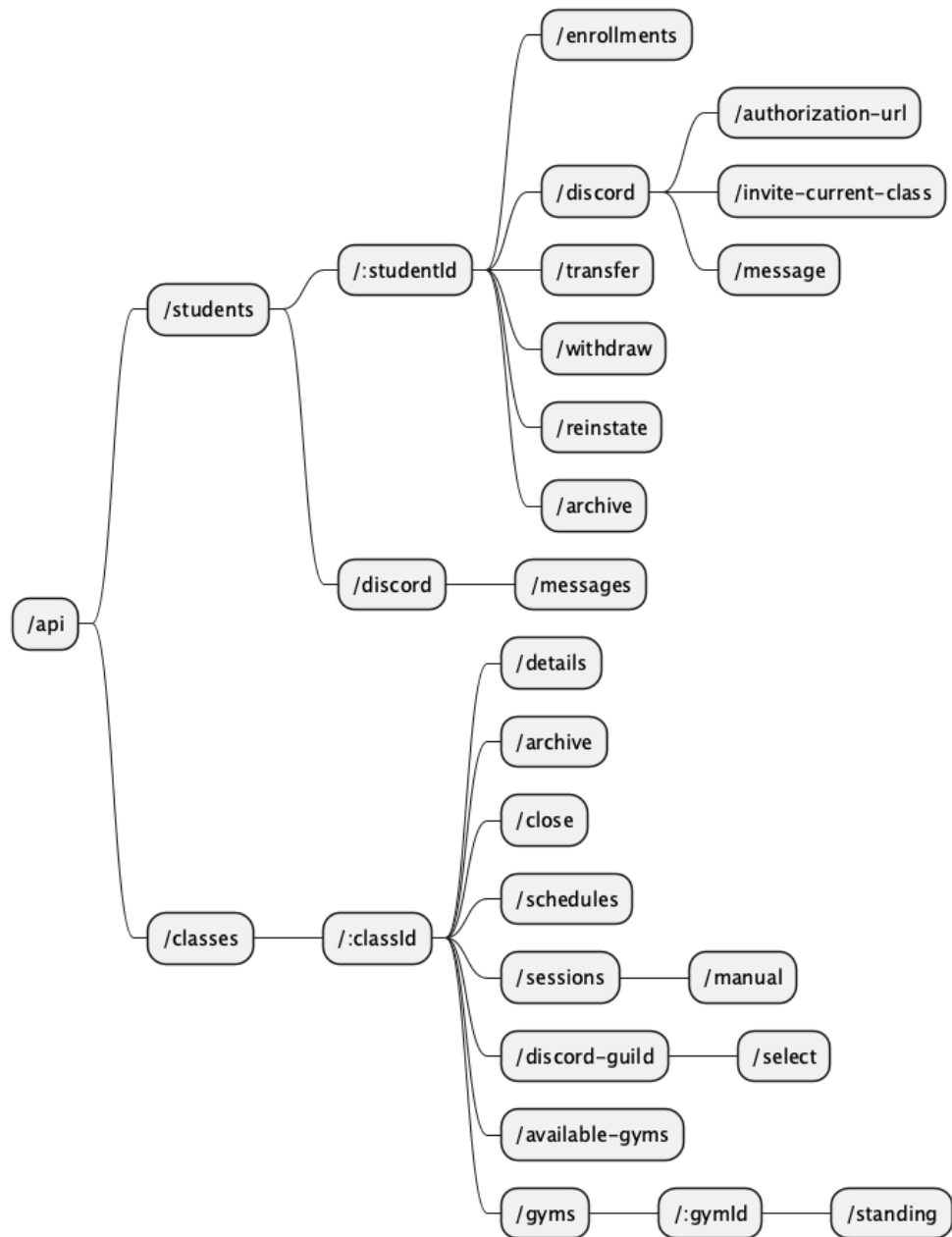
Hệ thống sử dụng REST API.



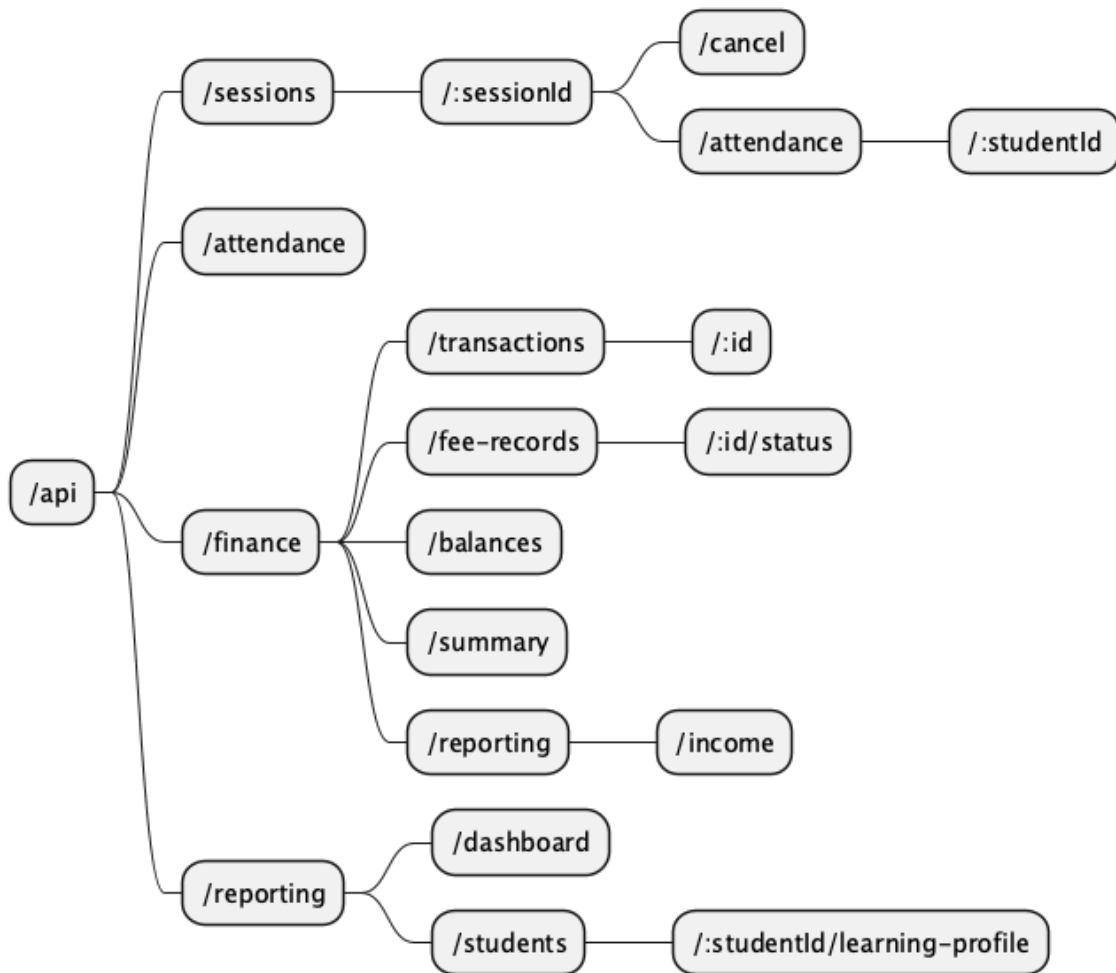
Hình 2: Các endpoint giao diện hiện tại của frontend



Hình 3: Các REST endpoint backend: tài khoản, quản trị và Discord

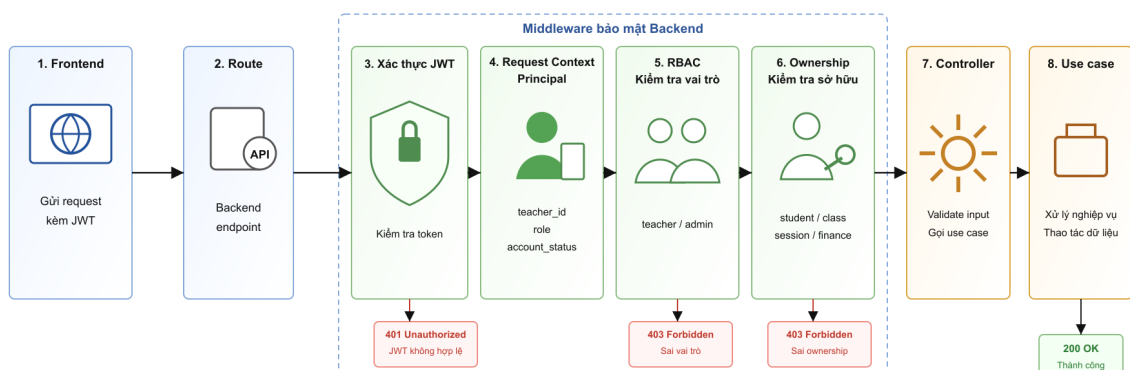


Hình 4: Các REST endpoint backend: học sinh và lớp học



Hình 5: Các REST endpoint backend: buổi học, điểm danh, tài chính và báo cáo

5. Bảo mật và kiểm soát truy cập



Hình 6: Luồng kiểm soát truy cập trước khi xử lý nghiệp vụ

Bảo mật được đặt ở lớp middleware của backend. Request từ frontend đi vào route backend, sau đó phải lần lượt qua các bước xác thực JWT, tạo request context, kiểm tra vai trò bằng RBAC và kiểm tra quyền sở hữu dữ liệu trước khi đến controller.

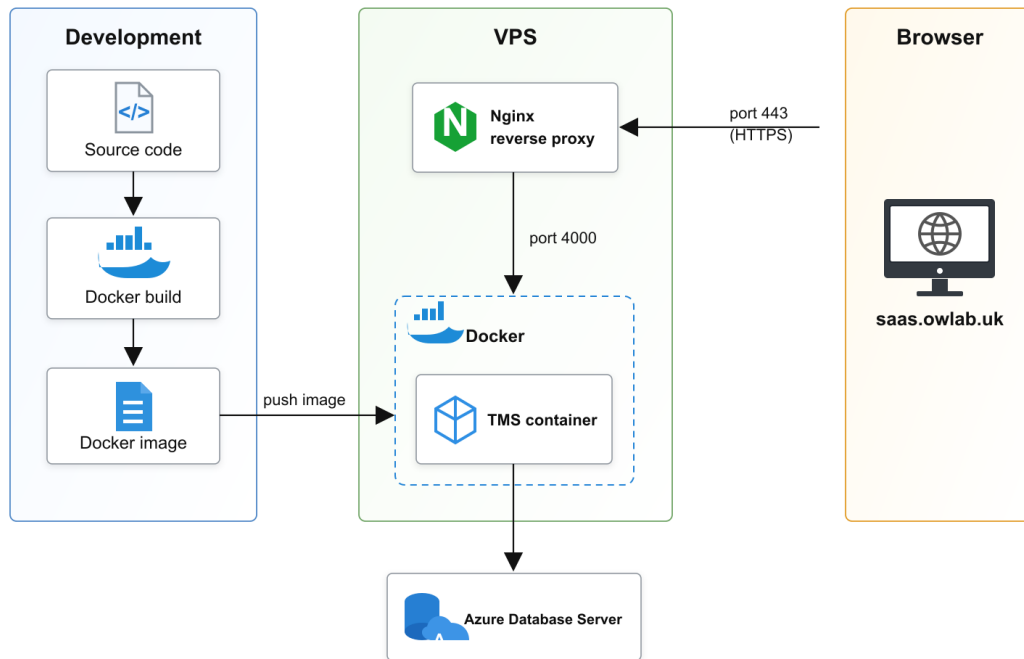
Quy tắc kiểm soát truy cập

- Mọi request cần đăng nhập phải gửi JWT trong header **Authorization:Bearer<token>**.
- JWT authentication kiểm tra chữ ký, thời hạn và định dạng token. Nếu token thiếu hoặc không hợp lệ, request bị chặn với **401Unauthorized**.
- Sau khi JWT hợp lệ, backend tạo principal trong request context, gồm **teacher_id**, **role** và trạng thái tài khoản.
- RBAC kiểm tra vai trò có được phép đi vào route hay không. Admin được dùng route quản trị; teacher được dùng route nghiệp vụ của giáo viên. Sai vai trò bị chặn với **403Forbidden**.
- Ownership check bảo đảm teacher chỉ truy cập dữ liệu thuộc phạm vi sở hữu của mình, gồm học sinh, lớp học, buổi học, hồ sơ tài chính và Gym được phân công. Sai phạm vi sở hữu cũng bị chặn với **403Forbidden**.

Mô tả luồng

1. Frontend gửi HTTP request kèm JWT đến backend route.
2. Route chuyển request qua middleware bảo mật.
3. Middleware xác thực JWT và trích xuất principal.
4. Hệ thống kiểm tra vai trò bằng RBAC.
5. Với route truy cập dữ liệu theo giáo viên, hệ thống kiểm tra ownership.
6. Request hợp lệ mới được chuyển đến controller và use case nghiệp vụ.
7. Kết quả xử lý được trả về cho frontend.

6. Sơ đồ triển khai



Hình 7: Sơ đồ triển khai phần mềm

1. Mã nguồn ở môi trường Development được build thành Docker image.
2. Docker image được push từ môi trường Development sang VPS.
3. Trên VPS, Docker chạy image này thành TMS container.
4. Người dùng mở Browser và truy cập domain `saas.owlab.uk`.
5. Request từ Browser đi vào VPS qua port 443.
6. Nginx trên VPS nhận request ở port 443 và đóng vai trò reverse proxy.
7. Nginx chuyển tiếp request vào TMS container qua port 4000.
8. TMS container kết nối đến Azure Database Server để đọc và ghi dữ liệu TMS.
9. TMS container xử lý request và trả kết quả ngược lại qua cùng đường đi.